



MASTG

MASVS-AUTH >

MASVS-NETWORK >

MASVS-PLATFORM >

MASVS-CODE >

MASVS-RESILIENCE >

MASVS-PRIVACY v

MASTG-TEST-0206: Undeclared PII in Network Traffic Capture

MASTG-TEST-0254: Dangerous App Permissions

MASTG-TEST-0255: Permission Requests Not Minimized

MASTG-TEST-0256: Missing



ANDROID

MASWE-0108

TEST



MASTG-TEST-0206: Undeclared PII in Network Traffic Capture

Overview

Attackers may capture network traffic from Android devices using an intercepting proxy, such as [ZAP \(Zed Attack Proxy\)](#), [Burp Suite](#), or [mitmproxy](#), to analyze the data being transmitted by the app. This works even if the app uses HTTPS, as the attacker can install a custom root certificate on the Android device to decrypt the traffic. Inspecting traffic that is not encrypted with HTTPS is even easier and can be done without installing a custom root certificate for example by using [Wireshark](#).

The goal of this test is to verify that sensitive data, specifically PII, is not being sent over the network, even if the traffic is encrypted. This test is especially important for apps that handle sensitive data, such as financial or health data, and should be performed in conjunction with a review of the app's privacy policy and the app's marketplace privacy declarations (e.g., Data Safety section in Google Play).

Steps

1. Start the device.
2. Start logging sensitive data from network traffic ([Logging Sensitive Data from Network Traffic](#)). For example using [mitmproxy](#).
3. Launch and use the app going through the various workflows while inputting sensitive data wherever you can. Especially, places where you know that will trigger network traffic.

Observation

The output should contain a network traffic log that includes the decrypted HTTPS traffic.

Evaluation

The test case fails if you can find the PII you entered in the app that is not declared in the app's marketplace privacy declarations (e.g., Data Safety section in Google Play) and/or in its privacy policy.

Note that this test does not provide any code locations where the sensitive data is being sent over the network. In order to identify the code locations, you can use static analysis tools like [semgrep](#) or dynamic analysis tools like [Frida](#). Consult [References to SDK APIs Known to Handle Sensitive User Data](#) and [Runtime Use of SDK APIs Known to Handle Sensitive User Data](#), respectively, for more details.

Demos

MASTG-DEMO-0009: Detecting Undeclared PII in Network Traffic